

Propuesta de Plan de Trabajo

Perímetro de Evaluación

Como Network Security Tester, mi enfoque principal es garantizar la resiliencia de la infraestructura virtual de NovaShop frente a posibles amenazas. Para la fase inicial de esta auditoría, se establece como prioridad delimitar el alcance técnico y operativo, asegurando que las partes interesadas comprendan con precisión el perímetro de evaluación, los activos involucrados y los límites éticos del proceso.

- **Alcance Técnico de la Evaluación**

Análisis de la Topología de Red: Identificación y categorización de los componentes de infraestructura (servidores, estaciones de trabajo y red corporativa).

Auditoría de Protocolos: Evaluación de protocolos de comunicación en uso, como HTTP/HTTPS, SSH, FTP/SFTP y protocolos de gestión como ARP, SNMP e ICMP.

Evaluación de Segmentación: Verificación teórica o simulada de reglas (ACL) para prevenir el acceso no autorizado entre estaciones de trabajo y servidores críticos.

Identificación de Superficie de Ataque: Mapeo del flujo de datos desde la aplicación web hasta las bases de datos internas para localizar puntos de falla o interceptación.

Control de Tráfico (IDS/IPS): Identificación teórica de puntos estratégicos para la implementación de sistemas de detección y prevención de intrusiones que permitan registrar y bloquear incidentes.

Simulación de Riesgos: Análisis de susceptibilidad a ataques de red como DoS (ICMP) y MITM (ARP Spoofing) debido a fallas de segmentación.

- **Exclusiones Éticas**

Explotación de Vulnerabilidades: No se realizan ataques reales ni explotación de fallos, el enfoque es la identificación y el análisis técnico profesional.

Ataques de Denegación de Servicio (DoS): Aunque se analizará la susceptibilidad a estos ataques vía ICMP, no se ejecutarán pruebas que comprometan la disponibilidad de los servicios.

Ingeniería Social: Queda fuera de este análisis cualquier intento de manipular al personal de NovaShop para obtener credenciales.

Alteración de Infraestructura Real: No se realizarán cambios de configuración en entornos productivos, cualquier simulación se hará en entornos controlados o de forma teórica.

Capa de Aplicación Profunda: Queda fuera de este alcance el manejo de cookies y la lógica interna de la aplicación web.

El enfoque se centrará en evaluar la seguridad del flujo de transacciones y la privacidad de los datos de los colaboradores, asegurando que el entorno virtual sea resiliente ante interrupciones operativas garantizando la Continuidad del Negocio.

Metodología de la Auditoría

En esta segunda etapa del proyecto, el enfoque evoluciona hacia una auditoría técnica detallada. El objetivo es establecer una línea base de seguridad robusta para NovaShop. Para profundizar en la auditoría, se aplicarán los siguientes criterios de evaluación sobre la infraestructura.

- **Auditoría , Clasificación y Diseño de Activos**

El objetivo de esta fase es establecer una línea de base sólida para la infraestructura de NovaShop, garantizando visibilidad total, seguridad eficiente y una gestión focalizada de los recursos.

Diagnóstico e Inventario Detallado

Identificaremos y mapearemos todos los activos tecnológicos, priorizando servidores internos y la red corporativa.

Alcance Lógico: Protocolos de red, bases de datos, servicios web, aplicaciones y sistemas operativos.

Alcance Físico: Actualización del inventario de componentes críticos:

- Cuartos de servidores y Racks.
- Sistemas de respaldo de energía (UPS).
- Sistemas de seguridad (Cámaras CCTV, lectores biométricos, paneles de alarma).

Diseño e Integración de Seguridad (Físico-Lógica)

Conectaremos la gestión de activos físicos con la lógica para una postura de seguridad integral.

- **Integración IAM (Identity and Access Management):** Sincronizar el sistema de control de acceso físico con el Directorio Activo (AD).

Acción automática: Si un empleado es deshabilitado en la red (lógico), su tarjeta de acceso físico se revoca automáticamente (físico).

Clasificación Estratégica por Criticidad

Organizaremos los recursos en niveles para aplicar controles de seguridad de forma eficiente y focalizada, determinando el valor y las vulnerabilidades de cada uno.

Nivel de Criticidad	Definición	Ejemplos

Críticos	Esenciales para la operación continua. Impacto alto si fallan.	Servidores de BD, Core Network, Directorio Activo, Cuarto de Servidores (acceso), Racks principales.
Secundarios	Importantes, pero con impacto moderado o mitigable..	Servidores de archivos de departamentos, herramientas internas, Sistemas UPS críticos, Cámaras CCTV en zonas de alto valor.
De Soporte	Infraestructura base o de apoyo. Impacto bajo.	Impresoras, estaciones de trabajo de usuarios no sensibles, Cámaras CCTV perimetrales, Paneles de alarma generales.

● Auditoría de Red y Topología

Mapeo de Red : Propongo identificar y categorizar todos los componentes de la infraestructura de red de la empresa . Lo que nos permite visualizar la superficie de ataque y evaluar los activos según su valor para el negocio.

- Evaluación de la topología y configuración de la red, realizar una adecuada identificación de cómo están interconectados los servidores internos, la red corporativa y las estaciones de trabajo.
- Realizar una clasificación por capas de la red: Acceso: Estaciones de trabajo de los empleados.Distribución/Core: Gestión de tráfico hacia los servidores internos.
- Identificación de Puntos de Falla: Localizar nodos donde la falta de redundancia o configuración insegura pueda comprometer la infraestructura virtual.
- Se propone la evaluación de sistemas de detección y prevención de intrusiones (IDS/IPS) como componentes críticos para la visibilidad del tráfico. Estos sistemas permitirán identificar y registrar intentos de acceso no autorizados, bloqueando amenazas antes de que logren propagarse entre los segmentos de red definidos (VLANs)y detectar inyecciones de SQL entre el servidor y la base de datos .

Mapeo del flujo de trabajo: Es de vital importancia rastrear el camino que sigue la información desde la aplicación web hasta las bases de datos internos

- Trazabilidad del viaje del dato: Rastreo del flujo desde que el usuario accede a la aplicación web hasta que la consulta llega al servidor interno.
- Identificar controles de segmentación:Verificar si existen reglas (ACL) que impidan que una estación de trabajo comprometida acceda directamente a los servidores críticos.

- Puntos de inspección y seguridad : Determinar en qué puntos de la red el tráfico es vulnerable a interceptación o ataques de hombre en el medio.

Evaluación del Cumplimiento de Normas y Regulaciones de Seguridad :Ayudar a garantizar el cumplimiento de las políticas ,estándares y procedimientos de controles de seguridad que se ajusten con los requisitos legales y regulatorios .

- Alineación con Marcos de Control
- Verificación de controles técnicos y políticas
- Trazabilidad y evidencia.

● Auditoría de Protocolos de Red

Auditoría de Protocolos de Capa de Aplicación:Es crítico evaluar los protocolos que puedan exponer datos sensibles de clientes .

- Seguridad Web (HTTPS vs. HTTP): Se debe verificar que la aplicación web no permite conexiones inseguras por el puerto 80.
- Integridad de DNS: Evaluar la configuración del servidor de nombres de dominio para prevenir que los clientes de NovaShop sean redirigidos a sitios fraudulentos.
- Seguridad en Arquitectura Multi-Capa (Web vs. App Server) :Se evaluará la resiliencia de la infraestructura distinguiendo entre el Servidor Web (responsable de la terminación segura de TLS y entrega de contenido estático) y el Servidor de Aplicaciones (gestor de la lógica de negocio y consultas a bases de datos).
- Validación de Punto a Punto: Se verificará que el cifrado HTTPS sea robusto en el servidor web para prevenir ataques de interceptación externos.
- Seguridad en el Backend: Se auditará que la comunicación interna entre el servidor de aplicaciones y la base de datos de NovaShop no sea vulnerable a inyecciones de tráfico o escalada de privilegios una vez superado el perímetro web.

Protocolos de Seguridad de Red :Protegen la comunicación y la infraestructura de la red .

- Administración Remota (SSH): Se debe validar el uso exclusivo de SSH para la gestión de servidores.
- Transferencia de Archivos (SFTP o. FTP): Para la actualización de activos digitales, se debe auditar que no se utilice el protocolo FTP tradicional por su falta de cifrado.
- Protocolos de Firewall : Validar que la configuración de estos protocolos cumpla con los requisitos de seguridad y políticas.

Protocolos de Gestión de Red :Garantizar la resiliencia de la red empresarial de NovaShop.

- ICMP: Evaluar si el exceso de respuestas ICMP permite el mapeo de la red interna o facilita ataques DoS.
- ARP : Analizar la susceptibilidad a ARP Spoofing, un riesgo alto si la segmentación entre las estaciones de trabajo y los servidores es deficiente.
- SNMP:Verificar la versión en uso,es imperativo validar si se está utilizando SNMPv3, que implementa cifrado y autenticación fuerte.

Protocolos de Cifrado HTTPS y TLS: Garantizar que el canal de comunicación entre los usuarios y los servidores de NovaShop sea impenetrable para terceros.

- Auditoría de versiones TLS: Validación del uso exclusivo de protocolos seguros, asegurando la desactivación de versiones obsoletas y vulnerables
- Análisis de Cipher Suites: Verificación de que los algoritmos de cifrado utilizados sean robustos y que no se permitan cifrados débiles que faciliten ataques de fuerza bruta o descifrado.
- Inspección de Encabezados de Seguridad: Evaluación de la implementación de HSTS para forzar conexiones seguras y prevenir ataques.
- Validación de Certificados: Revisión de la cadena de confianza, longitud de llaves y vigencia de los certificados digitales.

Evaluación Técnica de Riesgos Físicos y Operacionales (Continuidad del Negocio)

Este punto integra la gestión de riesgos para asegurar la resiliencia operativa:

Evaluación de Riesgos Físicos y Naturales:

- **Inspección:** Verificar controles de acceso físico al cuarto de servidores (biometría, CCTV, bitácoras).
- **Resiliencia Energética:** Evaluar la suficiencia de sistemas UPS y generadores redundantes para evitar corrupción de datos por apagones repentinos en la base de datos.
- **Mitigación Natural:** Validar la replicación geográfica de la base de datos AWS en múltiples Zonas de Disponibilidad.

Evaluación de Riesgos Tecnológicos y de Ciberseguridad:

- **Redundancia Topológica:** Auditar la configuración de Alta Disponibilidad, en firewalls y routers de borde para eliminar puntos únicos de fallo.
- **Segmentación IoT:** Validar que dispositivos IoT y cámaras físicas estén aislados en VLANs seguras, evitando que sean pivotes para movimiento lateral.

Evaluación de Riesgos Humanos y Operacionales

- **Seguridad VPN (Acceso Remoto):** Validar el cifrado extremo a extremo (IPsec/SSL) y la autenticación multifactor (MFA) para mitigar riesgos por credenciales robadas o errores humanos.
- **Cultura de Seguridad:** Evaluar la madurez del personal ante amenazas de Ingeniería Social (Phishing) mediante simulacros y formación continua.

Entregable: Matriz de Riesgos Final consolidando vulnerabilidades técnicas y riesgos operacionales, priorizados por severidad e impacto al negocio.

Análisis de Vulnerabilidades y Amenazas Identificadas

En esta tercera etapa, nuestro enfoque se centra en identificar y analizar los eventos potenciales que podrían comprometer la tríada de la seguridad en la infraestructura de NovaShop. No nos limitamos a identificar fallos técnicos aislados, sino a determinar cómo acciones malintencionadas podrían explotar las debilidades actuales de la red.

- **Vectores de Vulnerabilidad a Evaluar**

Basándonos en la topología de red y la infraestructura física de NovaShop, nuestra evaluación se focalizará en los siguientes vectores críticos:

Infraestructura Virtual y Nube (Riesgo Tecnológico/Natural):

Evaluación: Auditoría de configuraciones de hipervisor y riesgo de aislamiento de máquinas virtuales (VM Escape).

Continuidad: Validar la replicación geográfica de la base de datos AWS en múltiples Zonas de Disponibilidad para mitigar desastres naturales o fallos masivos del proveedor.

Comunicaciones de Red (Riesgo Tecnológico/Humano):

Evaluación: Análisis de protocolos susceptibles a ataques Man-in-the-Middle (HTTP, FTP, Telnet) y debilidades en la resolución de nombres (DNS/ARP) que afecten la integridad de los datos en tránsito .

Continuidad: Evaluar la resiliencia ante ataques de Denegación de Servicio (DoS) que saturen el firewall perimetral y paralicen la facturación.

Superficie de Ataque Inalámbrico y Física (Riesgo Físico/Humano):

Evaluación: Validación de la robustez de los protocolos de cifrado Wi-Fi (WPA2/WPA3) utilizados por el personal administrativo y detección de puntos de acceso fraudulentos (Rogue APs).

Continuidad: Inspección física del acceso al cuarto de servidores para mitigar sabotajes deliberados o acceso no autorizado a equipos de borde (Routers, Firewalls físicos).

Seguridad de Endpoints y BYOD (Riesgo Humano/Tecnológico):

Evaluación: Auditoría de la postura de seguridad en dispositivos móviles y portátiles personales que acceden a la red interna, verificando parches y protección antivirus.

Continuidad: Evaluar el impacto de malware o errores involuntarios de empleados descontentos que puedan propagarse a la red central.

- **Detalle de los Análisis por Área**

Para garantizar una evaluación exhaustiva, desglosamos los análisis técnicos a realizar:

- **Seguridad en Virtualización:** Auditoría física y de firmware en nodos de gestión, asegurando que routers y switches virtuales estén actualizados para prevenir intrusiones.
- **Gestión de Configuración y Parches:** Identificación de software desactualizado (CVE conocidos), firewalls mal configurados (reglas permisivas) y eliminación de contraseñas predeterminadas en dispositivos IoT.
- **Seguridad en Capas de Red y Servicios Web:**

Core: Evaluación de vulnerabilidades DNS/ARP y transición a SNMPv3 cifrado.

Web Server: Revisión de cifrado HTTPS/TLS para asegurar conexiones seguras y eliminar protocolos obsoletos.

App Server: Verificación de SSH y SFTP en el flujo dinámico entre la aplicación y la base de datos.

- **Amenazas del Entorno Operativo:** Evaluación de resiliencia ante Ingeniería Social (Phishing), gestión de amenazas internas y madurez en la respuesta a incidentes.

Entregable: Matriz de Evaluación de Vulnerabilidades y Riesgos

Al concluir esta etapa de análisis, se entregará una Matriz de Evaluación de Vulnerabilidades. Este documento detallará cada hallazgo, clasificándolas por tipo de riesgo (Físico, Tecnológico, Humano, Externo) y priorizando según su severidad (Alta, Media, Baja) y su impacto en la Continuidad del Negocio, facilitando la toma de decisiones estratégicas sobre las medidas de mitigación necesarias .

Plan de Mitigación de Riesgos

En esta etapa, documentaremos la estructura de las acciones correctivas estratégicas necesarias para fortalecer la postura de seguridad de NovaShop, basándonos directamente en los hallazgos de la fase de análisis. El objetivo de este documento es detallar las medidas técnicas que reducirán el impacto y la probabilidad de ocurrencia de las amenazas identificadas, priorizando los riesgos de severidad Alta para garantizar la Continuidad del Negocio.

- **Reforzamiento de Segmentación de Red y Control de Acceso:** Se describirá el procedimiento para la reconfiguración de reglas ACLs en Switches Core y Firewall perimetral para restringir el tráfico entre VLANs.

Objetivo: Explicar cómo se prohibirá el acceso directo de estaciones de trabajo de usuarios a servidores de base de datos críticos, aplicando el principio de menor privilegio para minimizar la superficie de ataque.

- **Fortalecimiento de Protocolos y Cifrado:** Se detallará la hoja de ruta para la implementación obligatoria de TLS en el servidor web (DMZ) y la desactivación de suites de cifrado débiles.

Objetivo: Explicar el proceso de migración definitiva de protocolos heredados y no cifrados (FTP, Telnet) a sus contrapartes seguras (SFTP, SSH), asegurando la confidencialidad de la información.

- **Gestión Proactiva de Parches y Físico-Operacional:** Se documentará el establecimiento de una política de actualización automatizada en hipervisores, firmware de dispositivos de red y sistemas operativos para prevenir la explotación de vulnerabilidades conocidas (CVEs).

Objetivo: Explicar las medidas para asegurar la disponibilidad física y lógica mediante la implementación de protocolos de emergencia, comunicación en crisis y pruebas periódicas del Plan de Continuidad.

- **Seguridad Inalámbrica y Endpoints (BYOD):** Se detallará la estrategia para la migración de cifrado Wi-Fi a WPA3 y la detección continua de puntos de acceso fraudulentos.

Objetivo: Explicar el marco para la implementación de políticas BYOD obligatorias, incluyendo agentes de seguridad (Antivirus/EDR) y cifrado de disco obligatorio para proteger los datos en dispositivos móviles.

Reporte Técnico-Ejecutivo y Cierre

Como fase final de la auditoría, consolidaremos los hallazgos y soluciones en un paquete de documentación estructurado. El objetivo de esta documentación no es solo entregar hallazgos técnicos, sino facilitar la toma de decisiones estratégicas para la dirección y proporcionar una guía de remediación precisa para el equipo técnico de NovaShop, asegurando la trazabilidad de todo el proceso de evaluación.

- **Resumen Ejecutivo (Dirección):** Un documento de alto nivel que presenta la postura de seguridad actual, destacando los riesgos críticos que afectan directamente al negocio (continuidad operativa, facturación, privacidad de datos de clientes) y la inversión estimada para la mitigación estratégica.
- **Reporte Técnico (Administración de Red):** Documento detallado con el minucioso análisis de las vulnerabilidades, evidencias recogidas, herramientas utilizadas y pasos técnicos recomendados para la remediación basada en la metodología de 7 pasos, incluyendo el análisis de configuraciones físicas y lógicas.
- **Matriz de Riesgos Final:** Documento guía que consolida el análisis de vulnerabilidades y el plan de mitigación, priorizando las acciones según su severidad técnica y el impacto al negocio, facilitando la auditoría de cumplimiento futuro y el seguimiento de la remediación.